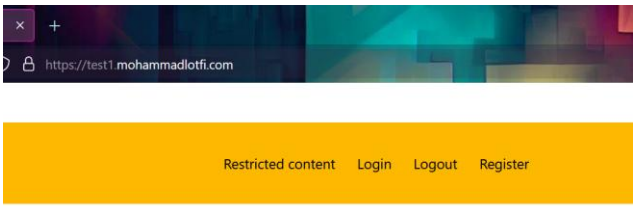
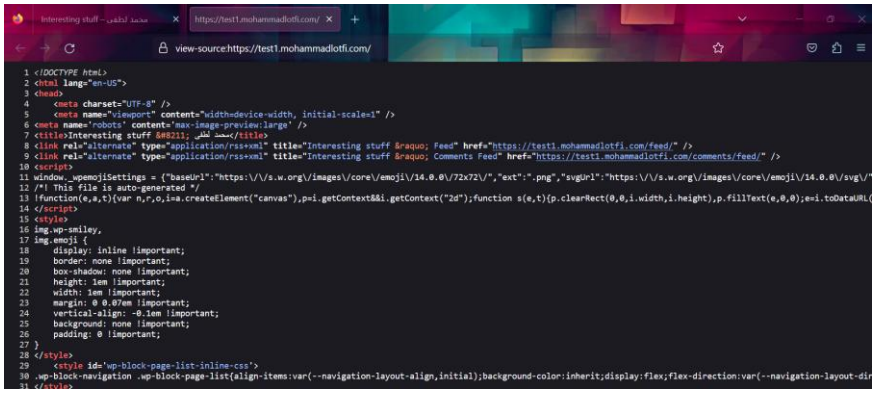
Custom 3 - (Very Hard):
I've made a website in here.
But it has the vulnerability CVE-2023-3460.
Can you do a privilege escalation attack and get the flag within the home page?

Steps undertaken to solve the challenge (this was learnt during the analysis and review session)

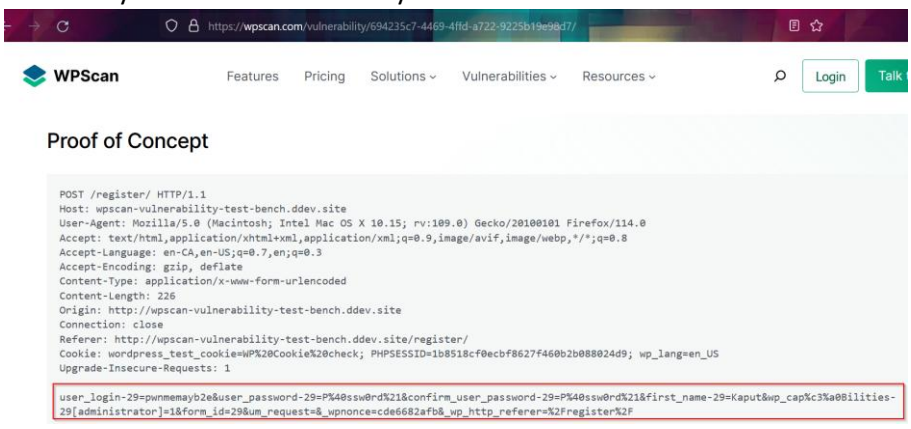
1. This is the home page we need to investigate:



   Inspecting the Source Code doesn't seem easy to get information from:

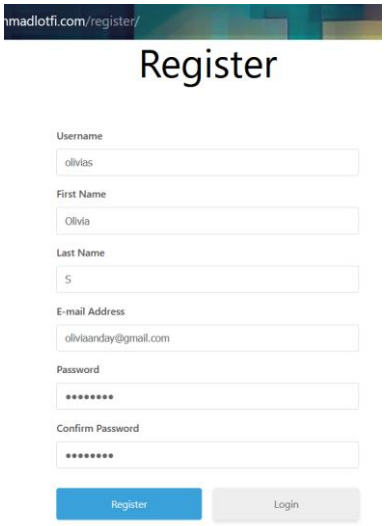


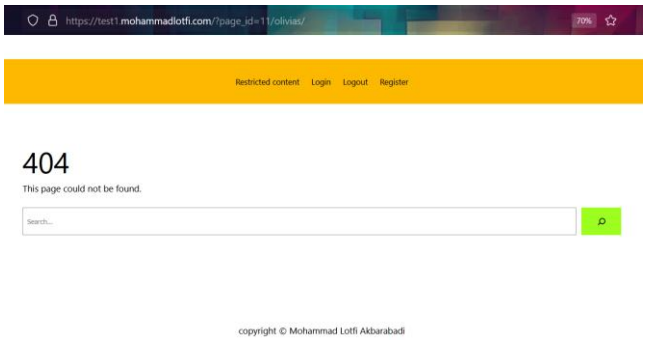
2. Let's study about the vulnerability CVE-2023-3460:

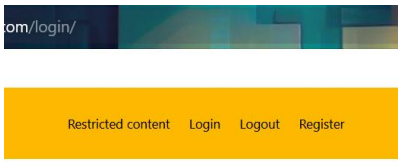


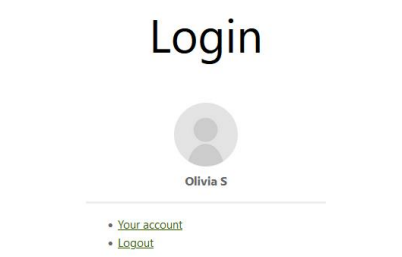
Referring to the Proof of Concept, we'll try to exploit the same vulnerability to perform privilege escalation attack and get the flag within the home page. We'll first register as a normal user, then we'll register using different username and try to change the role as "editor".

3. Register as a normal user:

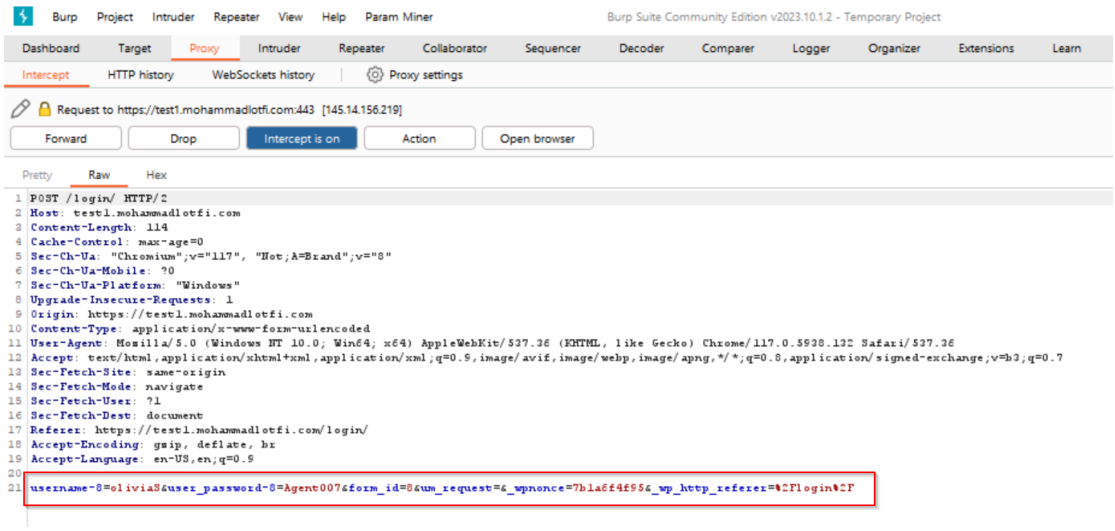




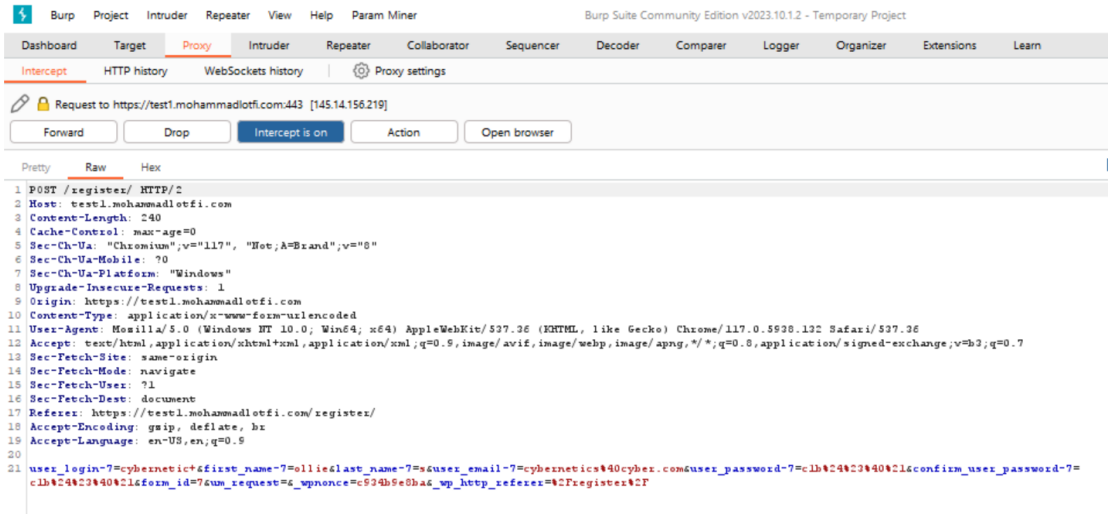




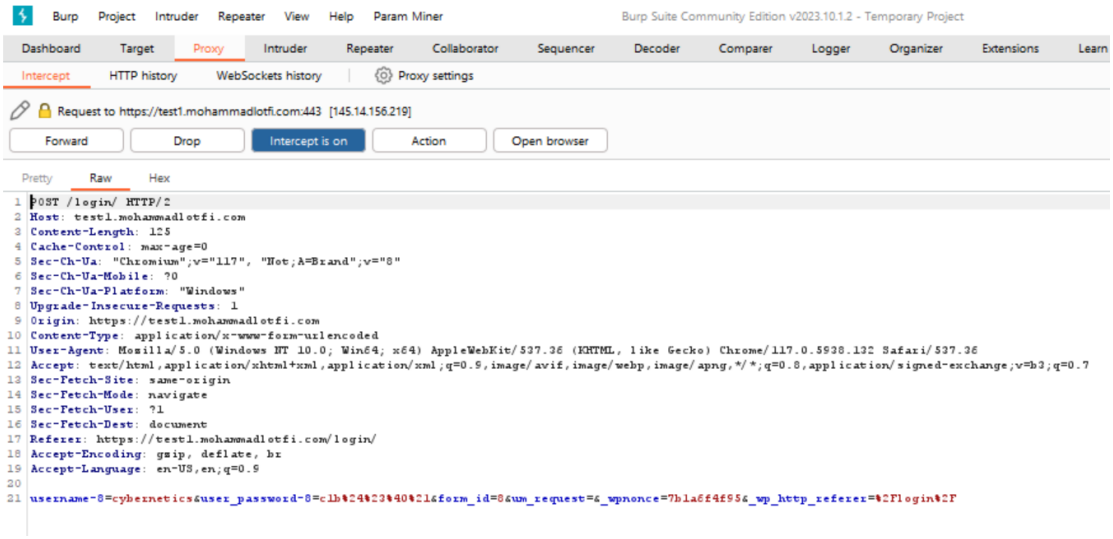
4. Start Burp Suite and login to the homepage and you'll see Burp Suite intercepted the username and password of this user:



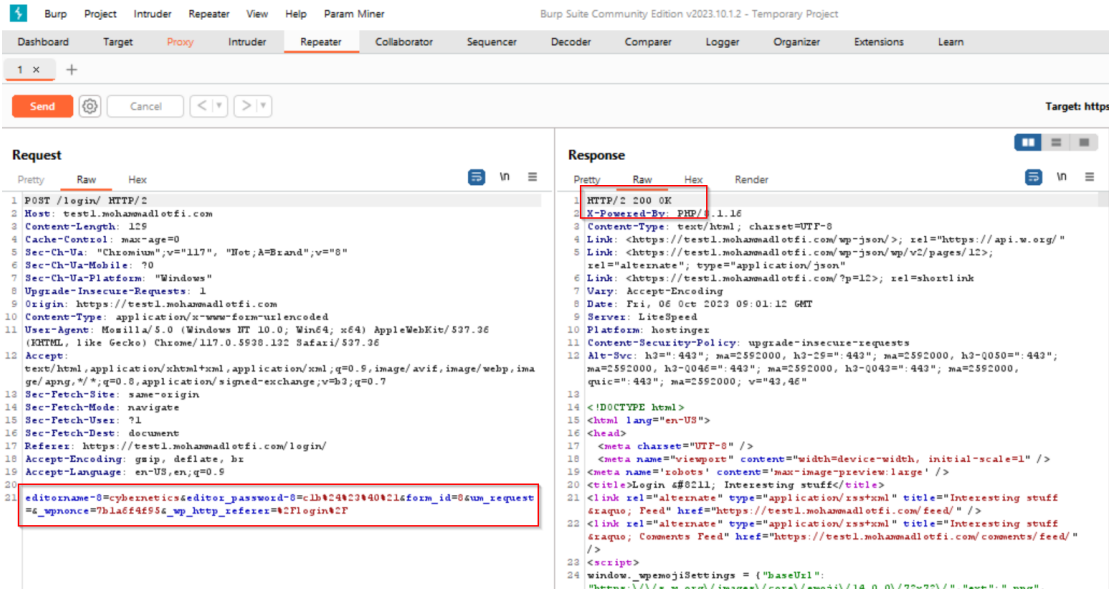
Register as user 2:



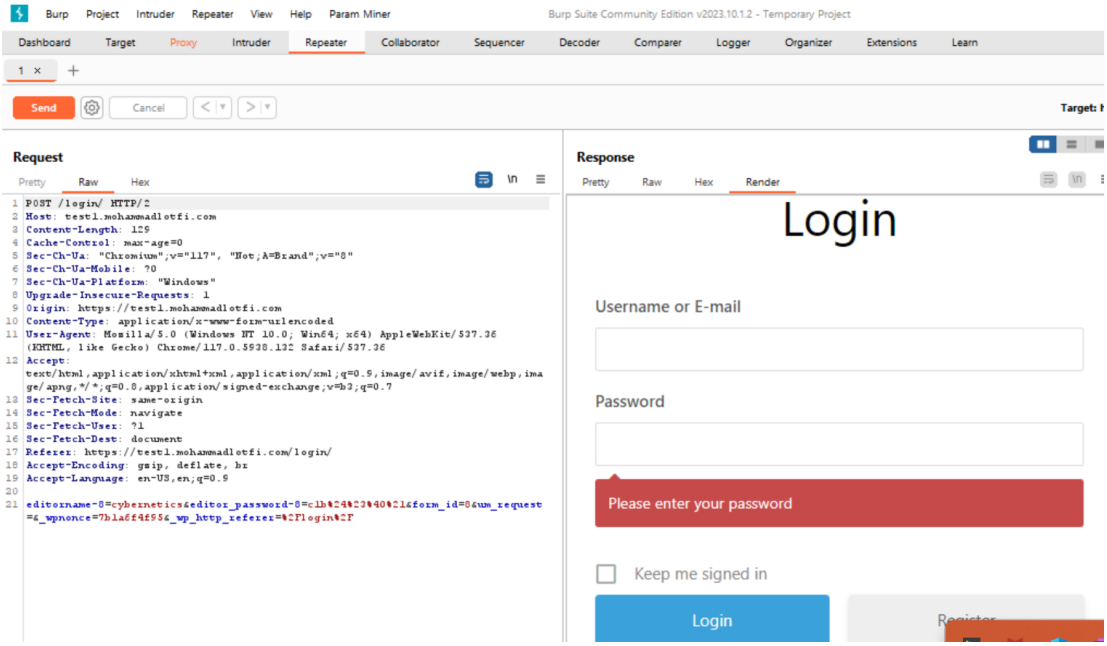
Copy and paste onto a notepad –note that there's no "wp-capabilities in the user information as in the hacked account – see report on RCE 2023-xxxx.

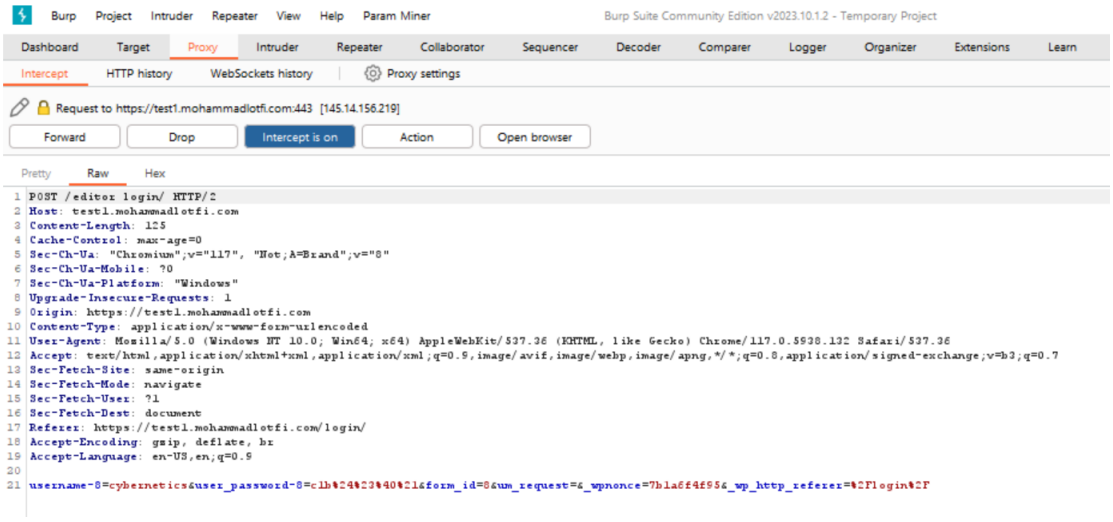


Change user to editor and send to Repeater:



See Render


Burp Project Intruder Repeater View Help Param Miner
Burp Suite Community Edition v2023.10.1.2 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn
Send Cancel
Request
Pretty Raw Hex
POST /login/ HTTP/2
Host: testl.mohammadlotfi.com
Content-Length: 129
Cache-Control: max-age=0
Sec-Ch-Ua: "Chromium";v="117", "Not;A=Brand";v="8"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Upgrade-Insecure-Requests: 1
Origin: https://testl.mohammadlotfi.com
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/117.0.5938.132 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://testl.mohammadlotfi.com/login/
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
editorname-8=cybernetics&editor_password-8=clb%24%23%40%21&form_id=8&um_request=&_wpnonce=7b1a6f4f95&_wp_http_referer=%2Flogin%2F
Response
Pretty Raw Hex Render
Login
Username or E-mail
Password
Please enter your password
Keep me signed in
Login


Burp Project Intruder Repeater View Help Param Miner
Burp Suite Community Edition v2023.10.1.2 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn
Intercept HTTP history WebSockets history Proxy settings
Request to https://test1.mohammadlotfi.com:443 [145.14.156.219]
Forward Drop Intercept is on Action Open browser
Pretty Raw Hex
POST /editor login/ HTTP/2
Host: testl.mohammadlotfi.com
Content-Length: 125
Cache-Control: max-age=0
Sec-Ch-Ua: "Chromium";v="117", "Not;A=Brand";v="8"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Upgrade-Insecure-Requests: 1
Origin: https://testl.mohammadlotfi.com
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/117.0.5938.132 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://testl.mohammadlotfi.com/login/
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
username-8=cybernetics&user_password-8=clb%24%23%40%21&form_id=8&um_request=&_wpnonce=7b1a6f4f95&_wp_http_referer=%2Flogin%2F